

Supporting Document Mandatory Technical Document: Evaluation Activities for collaborative Protection Profile Module for Server Applications

Foreword

This is a Supporting Document, intended to complement the Common Criteria (CC) version 3.1 Revision 5 and the associated Common Evaluation Methodology for Information Technology Security Evaluation.

Supporting Documents may be "Guidance Documents", that highlight specific approaches and application of the standard to areas where no mutual recognition of its application is required, and as such, are not of normative nature, or "Mandatory Technical Documents", whose application is mandatory for evaluations whose scope is covered by that of the Supporting Document. The usage of the latter class is not only mandatory, but certificates issued as a result of their application are recognized under the CCRA.

This Supporting Document has been developed by the iTC for Application Software iTC and is designed to be used to support the evaluations of TOEs against the cPP identified in [Section 1.1, "Technology Area and Scope of Supporting Document"](#).

Acknowledgements

This Supporting Document was developed by the iTC for Application Software international Technical Community with representatives from industry, Government agencies, Common Criteria Test Laboratories, and members of academia.

Revision History

Table 1. Revision history

Version	Date	Description
1.0	2022-04-06	Initial Release

Version	Date	Description
1.0e	2024-02-15	Incorporated feedback received following initial release.
2.0	2026-07-21	Draft-review updates.

General Purpose

See [Section 1.1, “Technology Area and Scope of Supporting Document”](#).

Field of special use

This Supporting Document applies to the evaluation of TOEs claiming conformance with the collaborative PP-Module for Server Applications.

Table of Contents

- Foreword..... 1
- Acknowledgements 1
 - Revision History 1
 - General Purpose 2
 - Field of special use..... 2
- 1. Introduction 3
 - 1.1. Technology Area and Scope of Supporting Document..... 3
 - 1.2. Structure of the Document 3
- 2. Evaluation Activities for SFRs 4
 - 2.1. Structure of EAs 4
 - 2.2. Representative Execution for Distributed TOE Components 5
 - 2.3. Justification for EAs for SFRs 7
 - 2.4. Security Management (FMT) 7
 - 2.4.1. Supported Configuration Mechanism (FMT_MEC_EXT)..... 7
 - 2.4.1.1. FMT_MEC_EXT.1.1/Server 7
 - 2.4.1.1.1. TSS 7
 - 2.4.1.1.2. Operational Guidance..... 8
 - 2.4.1.1.3. Test..... 8
 - 2.4.2. Specification of Management Functions (FMT_SMF) 8
 - 2.4.2.1. FMT_SMF.1.1/Server 8
 - 2.4.2.1.1. TSS 8
 - 2.4.2.1.2. Operational Guidance..... 8

2.4.2.1.3. Test	8
2.5. Protection of the TSF (FPT)	8
2.5.1. Anti-Exploitation Capabilities (FPT_AEX_EXT)	8
2.5.1.1. FPT_AEX_EXT.2.1/Server	8
2.5.1.1.1. TSS	8
2.5.1.1.2. Operational Guidance	9
2.5.1.1.3. Test	9
3. Evaluation Activities for Selection-Based Requirements	9
4. Evaluation Activities for SARs	9
5. References	10

1. Introduction

1.1. Technology Area and Scope of Supporting Document

This Supporting Document (SD) is mandatory for evaluations of products that claim conformance to any of the following cPP(s):

- collaborative PP-Module for Server Applications, Version 2.0, 2026-07-21

Although Evaluation Activities (EAs) are defined mainly for the evaluator to follow, the definitions in this SD aim to provide a common understanding for developers, evaluators and users as to what aspects of the TOE are tested in an evaluation against Collaborative Protection Profile for Application Software, and to what depth the testing is carried out. This common understanding in turn contributes to the goal of ensuring that evaluations against Collaborative Protection Profile for Application Software achieve comparable, transparent and repeatable results. In general, the definition of EAs will also help developers to prepare for evaluation by identifying specific requirements for their TOE. The specific requirements in EAs may in some cases clarify the meaning of SFRs, and may identify particular requirements for the content of Security Targets (STs) (especially the TOE Summary Specification (TSS)), AGD guidance, tests, and possibly required supplementary information (e.g. *any examples, such as for entropy analysis or cryptographic key architecture*).

1.2. Structure of the Document

EAs can be defined for both SFRs and SARs. These are defined in separate sections of this SD.

If any EA cannot be successfully completed in an evaluation then the overall verdict for the evaluation is a 'fail'. In rare cases there may be acceptable reasons why an EA may be modified or deemed not applicable for a particular TOE, but this must be agreed with the Certification Body for the evaluation.

In general, if all EAs (for both SFRs and SARs) are successfully completed in an evaluation then it would be expected that the overall verdict for the evaluation is a 'pass'. To reach a 'fail' verdict when

the EAs have been successfully completed would require a specific justification from the evaluator as to why the EAs were not sufficient for that TOE.

Similarly, at the more granular level of Assurance Components, if the Evaluation Activities for an Assurance Component and all of its related SFR Evaluation Activities are successfully completed in an evaluation then it would be expected that the verdict for the Assurance Component is a 'pass'. To reach a 'fail' verdict for the Assurance Component when these Evaluation Activities have been successfully completed would require a specific justification from the evaluator as to why the Evaluation Activities were not sufficient for that TOE.

2. Evaluation Activities for SFRs

2.1. Structure of EAs

All EAs for SFRs defined in this Section include the following items to keep consistency among EAs.

1. Objective of the EA

Objective defines the goal of the EA. Assessment Strategy describes how the evaluator can achieve this goal in more detail and Pass/Fail criteria defines how the evaluator can determine whether the goal is achieved or not.

2. Dependency

Where the EA depends on completion of another EA then the dependency and the other EA is also identified here.

3. Tool types required to perform the EA

If performing the EA requires any tool types in order to complete the EA then these tool types are defined here.

4. Required input from the developer or other entities

Additional detail is specified here regarding the required format and content of the inputs to the EA.

5. Assessment Strategy

Assessment Strategy provides guidance and details on how to perform the EA. It includes, as appropriate to the content of the EA;

- a. How to assess the input from the developer or other entities for completeness with respect to the EA
- b. How to make use of any tool types required (potentially including guidance for the calibration or setup of the tools)

c. Guidance on the steps for performing the EA

6. Pass/Fail criteria

The evaluator uses these criteria to determine whether the EA has demonstrated that the TOE has met the relevant requirement or that it has failed to meet the relevant requirement.

7. Requirements for reporting

Specific reporting requirements that support transparency and reproducibility of the Pass/Fail judgement are defined here.

2.2. Representative Execution for Distributed TOE Components

For a distributed TOE, every TOE Component to which an SFR is allocated shall satisfy that requirement, every TOE Component Instance shall exhibit the claimed behavior of its TOE Component in its identified configuration, and every applicable artifact, interface, communication relationship, configuration, and deployment context shall be covered by the EAs at their stated scope. A Component Implementation-Equivalence Class groups named SFR Implementation Instances used by TOE Components and identified security-relevant configurations where applicable; it does not group or eliminate coverage of interfaces or communication relationships. An SFR Implementation Instance is a unique use of an implementation by a TOE Component, in an identified security-relevant configuration where applicable, to satisfy one or more SFRs. Additional Runtime Replicas that deploy that use do not create additional SFR Implementation Instances. Representative execution with complete class-membership verification is not sampling.

The ST shall provide concise traceability from each TOE Component and identified security-relevant configuration, where applicable, to its SFR iteration and, where evidence reuse is claimed, to a class identifier and common TSS description. The ST may identify unambiguous sets of TOE Components and configurations and need not map them to individual EAs. The developer shall provide an implementation-equivalence rationale, which may be separate from the ST, identifying the class members, all SFR iterations covered, and the exact implementation-specific EA paragraphs or test identifiers for which reuse is proposed.

Class members shall have the same security-relevant implementation and version, wrapper or integration behavior, security-relevant build options, implementation configuration and values relevant to the reused activities, role and exercised code path, cryptographic provider where applicable, and immediate platform services and interfaces relevant to the reused activities. Channel-specific certificates, keys, trust-anchor values, endpoint identities, addresses, and similar deployed values may differ when they do not alter the reused implementation behavior and are covered by retained interface- or channel-specific activities. The rationale shall identify peripheral differences reasonably capable of affecting the scoped results and explain why they cannot do so. A common base image, runtime, library name, source repository, or build pipeline alone is not sufficient. When the prerequisites or the effect of a relevant peripheral difference cannot be substantiated, the affected SFR

Implementation Instances may not share representative execution for that scope.

The evaluator shall examine objective evidence for every claimed class member and select one or more representative class-member SFR Implementation Instances and, for each, an exact deployed TOE Component Instance through which it will be exercised. The selected SFR Implementation Instances and deployed TOE Component Instances shall collectively expose all behavior relevant to the identified activities. Objective evidence may include artifact identifiers or hashes, dependency manifests, software bills of materials, build records, configuration records, or observed invocation paths. If they do not expose all relevant behavior, the evaluator shall require additional execution or determine that the class is not substantiated for that scope.

The base cPP Supporting Document's general guidance for Linux-container application payloads applies to every Running-Payload Activity portion of an EA in this Supporting Document. Image, runtime, and orchestrator differences are evaluated separately when they are outside the scope of a running-payload activity. If one of those differences can affect a proposed reused running-payload result, it is also a class-relevant difference and shall be addressed by the implementation-equivalence rationale.

Representative execution eliminates only duplicate execution of the same implementation-specific activity across class members. It does not reduce any test count, parameter combination, supported algorithm, protocol role, configuration, certificate case, negative test, artifact, interface, channel, communication relationship, deployment context, or end-to-end coverage required by the originating EA. A single execution may be cited for more than one SFR Implementation Instance, SFR, or EA only when it demonstrates every applicable objective and the evaluator preserves a separate coverage mapping and verdict for each.

The evaluation report shall identify each class, the membership evidence examined, the representative SFR Implementation Instance or instances selected, the exact deployed TOE Component Instances used for execution, the activities performed, the repetitions not performed, and the artifact-, interface-, channel-, configuration-, deployment-, and end-to-end checks performed separately. Use of this procedure does not deem an EA inapplicable or transfer compliance from one TOE Component or identified configuration to another.

For TLS and similar trusted-channel testing, multiple TOE Components or identified security-relevant configurations may share the complete protocol-implementation test suite only when the SFR Implementation Instances of their substantiated TLS implementation meet the class prerequisites above. Every distinct interface and channel remains subject to the required connection, credential, trust, identity, traffic-protection, interruption, recovery, and integration checks, and all internal repetitions required by the protocol EA shall be performed on the selected TOE Component Instance or instances. TLS termination performed by an operational-environment service mesh or ingress component is an environmental dependency, not a shared TOE implementation, unless that component is explicitly included in the TOE boundary. An operational-environment termination point cannot be credited as satisfying FTP_DIT_EXT.1 or another TOE-implemented channel requirement unless the applicable SFR expressly permits platform-provided functionality.

2.3. Justification for EAs for SFRs

EAs in this SD provide specific or more detailed guidance to evaluate the *type of* system, however, it is the CEM work units based on which the evaluator shall perform evaluations.

This Section explains how EAs for SFRs are derived from the particular CEM work units identified in Assessment Strategy to show the consistency and compatibility between the CEM work units and EAs in this SD.

Assessment Strategy for ASE_TSS requires the evaluator to examine that the TSS provides sufficient design descriptions and its verdicts will be associated with the CEM work unit ASE_TSS.1-1. Evaluator verdicts associated with the supplementary information will also be associated with ASE_TSS.1-1, since the requirement to provide such evidence is specified in ASE in the cPP.

Assessment Strategy for AGD_OPE/ADV_FSP requires the evaluator to examine that the AGD guidance provides sufficient information for the administrators/users as it pertains to SFRs, its verdicts will be associated with CEM work units ADV_FSP.1-7, AGD_OPE.1-4, and AGD_OPE.1-5.

Assessment Strategy for ATE_IND requires the evaluator to conduct testing that the iTC has determined that those testing of the TOE in the context of the associated SFR is necessary. While the evaluator is expected to develop tests, there may be instances where it is more practical for the developer to construct tests, or where the developer may have existing tests. Therefore, it is acceptable for the evaluator to witness developer-generated tests in lieu of executing the tests. In this case, the evaluator must ensure the developer's tests are executing both in the manner declared by the developer and as mandated by the EA. The CEM work units that derive those EAs are: ATE_IND.1-3, ATE_IND.1-4, ATE_IND.1-5, ATE_IND.1-6, and ATE_IND.1-7.

2.4. Security Management (FMT)

2.4.1. Supported Configuration Mechanism (FMT_MEC_EXT)

2.4.1.1. FMT_MEC_EXT.1.1/Server

2.4.1.1.1. TSS

The evaluator shall review the TSS to identify where the application's configuration data is stored. The evaluator shall also verify that the TSS identifies who has read and write access to the configuration data.

For a Linux-container application payload, the TSS shall distinguish configuration baked into the image from configuration supplied through mounted files or volumes, injected environment or command-line values, runtime APIs, and orchestrator-managed configuration objects. It shall identify the effective path or interface used by the running payload and the source or attachment layer that controls each value.

2.4.1.1.2. Operational Guidance

No activities specified.

2.4.1.1.3. Test

The evaluator shall run the following tests:

- Test 1: The evaluator shall verify that the access rules for the configuration files and other configuration sources or attachment mechanisms align with the read and write access identified in the TSS.

2.4.2. Specification of Management Functions (FMT_SMF)

2.4.2.1. FMT_SMF.1.1/Server

2.4.2.1.1. TSS

No activities specified.

2.4.2.1.2. Operational Guidance

The evaluator shall verify that every management function specified in the SFR is described in the operational guidance. If multiple management interfaces are supported, the guidance documentation must describe which interfaces may be used to perform the management functions.

2.4.2.1.3. Test

The evaluator shall perform the following test:

- Test 1: The evaluator shall test the application's ability to provide each management function by configuring the application and testing each function specified. The evaluator is expected to test these functions in all the ways in which the ST and guidance documentation state the configuration can be managed. Each function should be tested on each management interface on which the functionality is supported.

2.5. Protection of the TSF (FPT)

2.5.1. Anti-Exploitation Capabilities (FPT_AEX_EXT)

2.5.1.1. FPT_AEX_EXT.2.1/Server

2.5.1.1.1. TSS

No activities specified.

2.5.1.1.2. Operational Guidance

No activities specified.

2.5.1.1.3. Test

The evaluator shall configure the platform in the ascribed manner and carry out one of the prescribed tests:

- Test 1: [conditional] If the application is being tested on Windows, the evaluator shall perform the Windows test specified for FPT_AEX_EXT.1.3 in the Collaborative Protection Profile for Application Software. The evaluator shall additionally confirm that the selected process mitigations apply to the Server Application process or service execution model.
- Test 2: [conditional] If the Server Application is a Linux-container payload, the evaluator shall perform the Linux test specified for FPT_AEX_EXT.1.3 in the Collaborative Protection Profile for Application Software. The evaluator shall additionally verify that the mandatory access control applied by the evaluated container runtime or orchestrator reaches the running payload in enforcing mode: for SELinux, the applicable security domain shall not be permissive; for AppArmor, an enforce-mode profile shall apply to the container or application process. The evaluator shall then demonstrate application startup and representative security-relevant operations without disabling the control or placing the applicable policy or profile in a permissive, complain, learning, or audit-only mode.
- Test 3: [conditional] If the application is being tested on macOS, the evaluator shall perform the macOS test specified for FPT_AEX_EXT.1.3 in the Collaborative Protection Profile for Application Software with System Integrity Protection (SIP) enabled.

3. Evaluation Activities for Selection-Based Requirements

This PP-Module does not define selection-based requirements. Component participation control is addressed by the Agent module when a PP-Configuration includes Agent Applications. Protection of data transmitted between TOE Component Instances is addressed by FTP_DIT_EXT.1 in the base cPP. Certificate validation and certificate path processing requirements are addressed by the X.509 package selected through the base cPP, where applicable.

4. Evaluation Activities for SARs

The PP-Module does not define any SARs beyond those defined within the App PP base to which it must claim conformance. It is important to note that a TOE that is evaluated against the PP-Module is inherently evaluated against this Base-PP as well. The Collaborative Protection Profile for Application Software includes a number of Evaluation Activities associated with both SFRs and SARs. Additionally, the PP-Module includes a number of SFR-based Evaluation Activities that similarly refine the SARs of the Base-PPs. The evaluation laboratory will evaluate the TOE against the Base-PP and supplement that

evaluation with the necessary SFRs that are taken from the PP-Module.

5. References

- [CC1] Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and General Model, CCMB-2022-11-001, CC:2022, Revision 1, November 2022.
- [CC2] Common Criteria for Information Technology Security Evaluation, Part 2: Security Functional Components, CCMB-2022-11-002, CC:2022, Revision 1, November 2022.
- [CC3] Common Criteria for Information Technology Security Evaluation, Part 3: Security Assurance Components, CCMB-2022-11-003, CC:2022, Revision 1, November 2022.
- [CEM] Common Methodology for Information Technology Security Evaluation, Evaluation Methodology, CCMB-2022-11-006, CC:2022, Revision 1, November 2022.
- [ERR] Errata and Interpretation for CC:2022 (Release 1) and CEM:2022 (Release 1), CCMB-2024-02-001, Version 1.0, 1 February 2024
- [cPP] Collaborative Protection Profile for Application Software, Version 2.0, 2026-07-21